Boletín Digital
SEGURIDAD DE LA INFORMACION

Oficina de Gestión de Información Ambiental y Tecnologías de Apoyo Boletín No. 1 – Diciembre 23 de 2019

Protección del puesto de trabajo. Escenarios de Riesgo

En multitud de ocasiones, tendemos a relacionar la ciberseguridad de una empresa con grandes inversiones en la implantación de medidas tecnológicas orientadas a la protección de la información: sistemas de detección de intrusos, controles de acceso a las instalaciones, salas de servidores, ***firewalls***, etc.

Sin embargo, hay que tener en cuenta que, cuando hablamos de ciberseguridad, la pieza fundamental es el usuario. Por muchas medidas tecnológicas que se tengan implementadas en una organización, será el usuario final el que, en última instancia, deberá entender si sus acciones guardan o no relación con la ciberseguridad. Para conseguirlo, será fundamental incidir e invertir en la formación y la concienciación del personal de la empresa.

Uno de los aspectos en los que se tiene que estar plenamente concienciado es en conocer los escenarios de riesgo asociados a su puesto de trabajo, así como las medidas que reducirán o evitarán dichas situaciones. El puesto de trabajo es algo más que la ubicación física en la que un empleado desarrolla sus funciones, ya que también están presentes otros elementos que guardan relación con la seguridad de la información: ***smartphones***, tabletas, dispositivos de almacenamiento externos o extraíbles, impresoras, documentación física, archivadores, etc.

Por lo tanto, mitigar todos los riesgos no siempre requerirá de grandes inversiones tecnológicas, sino de una cultura en ciberseguridad que pueda conjugarse con las medidas técnicas para proteger el principal activo con el que cuenta una empresa, la información.

ESCENARIOS DE RIESGO EN RELACIÓN AL PUESTO DE TRABAJO

Entendemos como escenarios de riesgos las situaciones como las que se describen a continuación:

PRÁCTICAS POCO RECOMENDABLES

En ocasiones, las fugas o pérdidas de información se producen por llevar a cabo malas prácticas que bien pueden ser aprovechadas por atacantes externos, o que simplemente provocan consecuencias no deseadas. Por ejemplo, si un empleado instala alguna aplicación que base su actividad en compartir archivos y, por error, compartiera un directorio con información confidencial, incurriría en una pérdida de datos. Para evitar este tipo de situaciones, a

nivel técnico será necesario controlar qué aplicaciones se pueden instalar en los equipos corporativos y con qué permisos contarán a la hora de acceder a la información corporativa.

También se podría dar el caso de que un empleado copiara en un dispositivo extraíble información confidencial, cuyo único fin fuera seguir trabajando desde casa. Si este dispositivo se extraviara, y alguien lo encontrara, estaría en posesión de toda la información contenida. Para evitar estas situaciones se puede establecer una política de dispositivos extraíbles que permita a la empresa decidir si autoriza o no el uso de estos dispositivos, así como diseñar las medidas de seguridad que garanticen la protección de la información contenida, como por ejemplo, cifrando los datos que alberga o estableciendo contraseñas robustas para su acceso.

En ambos casos, si el usuario fuera consciente de la problemática, con independencia de las medidas técnicas que se pudieran tomar, evitaría estas situaciones de riesgo, bien porque fuera consciente de que no debe instalar aplicaciones que no sean fiables o que procedan de fuentes poco confiables, o bien porque supiera que un dispositivo externo se puede proteger con contraseña o cifrarse, para que la información que contiene no pueda ser accesible sin conocer la clave de descifrado.

FUGAS DE INFORMACIÓN QUE TIENEN COMO ORIGEN EL PUESTO DE TRABAJO

Se trata de aquellas situaciones en las que, ya sea de manera malintencionada por parte de empleados descontentos, o por simples despistes o desconocimiento, se producen fugas o pérdidas de información a través de herramientas que tienen como origen el propio puesto de trabajo. Por ejemplo, mediante el envío de correos electrónicos a personal ajeno a la organización o mediante publicaciones en redes sociales que sean dañinas para la imagen y reputación de una empresa.

Pero también pueden producirse físicamente con fines maliciosos, es decir, mediante la impresión de datos confidenciales sobre márgenes de venta, información personal, etc., con fines maliciosos.

Una de las principales medidas a la hora de proteger la información, es utilizar el principio del mínimo privilegio. Se trata de que los usuarios únicamente accedan a aquella información que sea estrictamente necesaria para el desempeño de sus funciones diarias. Con este tipo de control evitaremos muchas de estas situaciones.

10 MEDIDAS DE SEGURIDAD PARA PROTEGER TU PUESTO DE TRABAJO

En la mayoría de las empresas hay un encargado o un departamento (Depende del tamaño de estas) que se dedica a supervisar aspectos sobre la seguridad de los equipos o sistemas que se utilizan habitualmente.

Sin embargo, salvaguardar la seguridad de la información que manejamos dentro de nuestro puesto de trabajo es tarea de todos.

Manejamos más información de la que creemos y en mayor o menor medida trabajamos con material sensible. En este contexto, hay 10 consejos que ampliaremos en nuestro informe sobre seguridad en el trabajo.

Boletín Digital

SEGURIDAD DE LA INFORMACION

1. MANTENER LA CONFIDENCIALIDAD

No debemos facilitar información de carácter confidencial a externos de la empresa. Esto implica no compartir información corporativa sobre clientes o proyectos en redes sociales o en una conversación que creemos informal. Facilitar estos datos nos podría convertir en víctimas de ataques de ingeniería social que tienen como objetivo empleados de nuestra organización.

2. NO ALTERAR LA CONFIGURACIÓN DEL EQUIPO

Esto implica evitar la instalación de aplicaciones no autorizadas o, en caso de necesitarlo, recurrir al personal de informática de la empresa. En caso de que estemos utilizando dispositivos portátiles entre los que se incluyen smartphones o tabletas, debemos tener las mismas precauciones.

3. BLOQUEO AUTOMÁTICO DE LA SESIÓN CUANDO NOS AUSENTAMOS DEL PUESTO DE TRABAJO Y AL TERMINAR LA JORNADA LABORAL.

Es especialmente relevante este apartado de las recomendaciones de seguridad, en los entornos en los que se comparten espacios de trabajo o están especialmente expuestos al público. De esta forma nos evitamos las miradas indiscretas o las pérdidas o robo de información que nos pueden generar bastantes problemas. Para ello, es esencial instaurar una política de mesas limpias en la cual como trabajadores debemos asegurarnos de que nuestro puesto de trabajo esté limpio y ordenado, con la documentación guardada y no dejar ninguna contraseña apuntada en post it o similares. Y, por último, lo que se indica en el título, asegurarse de bloquear siempre la sesión cuando abandonemos el puesto o apagar el ordenador correctamente al final de nuestra jornada laboral.

4. DESTRUCCIÓN DE DOCUMENTACIÓN

Debemos deshacernos de la información que ya no vamos a utilizar de forma segura. Para este propósito podemos utilizar destructoras de papel y evitar tirar documentos sensibles como datos personales, información financiera etc. En papeleras comunes.

5. UTILIZACIÓN DEL CORREO CORPORATIVO E INTERNET DE MANERA RESPONSABLE

Únicamente debemos hacer uso de internet o del correo para la actividad laboral. Sin embargo, la empresa por su parte debe informarnos siempre de si existe algún tipo de sistema de registro de accesos a internet.

6. ATENCIÓN ESPECIAL A LA UTILIZACIÓN DE DISPOSITIVOS PERSONALES DE USO MIXTO

Cada vez es más habitual acceder con dispositivos de uso personal a las redes de la empresa para cubrir necesidades específicas en un momento concreto. Pero, si se da esta circunstancia, los empleados deben saber

que, para acceder a estos recursos corporativos, sus dispositivos deben adaptarse con configuraciones específicas y a las medidas de seguridad que decida la organización.

7. USAR ADECUADAMENTE LOS DISPOSITIVOS DE ALMACENAMIENTO EXTRAÍBLE

Los dispositivos de almacenamiento externo, pendrives y discos duros, son especialmente peligrosos, por su facilidad a la hora de sustraerlos, olvidarlos o que se corrompan y perder la información que contienen. Por ello, es recomendable limitar su uso o utilizar repositorios comunes o utilizar almacenamientos online, para evitar la pérdida de información sensible.

8. GENERACIÓN DE CONTRASEÑAS SEGURAS

A la hora de crear una contraseña hay varias recomendaciones de seguridad que podemos seguir:

- Las contraseñas deberían estar compuestas como mínimo de 8 caracteres.
- Debemos intercalar números, letras y mayúsculas con minúsculas.
- Cambiar la contraseña cada seis meses aproximadamente.
- No debe contener tres letras consecutivas del nombre del usuario.

9. LIMITACIÓN DE LOS USUARIOS CON ACCESO AL CLOUD

El almacenamiento online es extremadamente útil para evitar la pérdida de información y tener todo en un mismo lugar para acceder a ello más rápidamente dentro y fuera de la oficina, pero implica algunos riesgos que nos obligan como usuarios a tomar algunas precauciones:

Cada usuario debe ser único y no utilizar el perfil de usuario corporativo para uso privado.

Todos los usuarios deben ser autorizados por el personal de informática.

No utilizar estos servicios como repositorios permanentes, si no como repositorios temporales.

10. NOTIFICAR LOS INCIDENTES

Por último, debemos notificar cualquier incidente que advirtamos al servicio de informática para que nos avise de cómo proceder ante emails sospechosos, perdida de dispositivos móviles, borrado accidental de ficheros o comportamientos anómalos del sistema.

FUNCIONALIDADES AUTOMÁTICAS

Se pueden dar una serie de circunstancias en las que una funcionalidad automática nos podría jugar una mala pasada. Por ejemplo, a la hora de escribir el destinatario de un correo electrónico, solemos utilizar la función de autocompletado haciendo clic en uno de los elementos del listado de direcciones que nos ha aparecido automáticamente, sin detenernos a verificar que hemos seleccionado el destinatario correcto. Se trata de una acción que realizamos de manera mecánica, ante la que un mínimo fallo sería suficiente para enviar información confidencial o datos especialmente protegidos a personal ajeno a la organización o que simplemente, no deba estar en posesión de la misma.

Para evitar estas situaciones será necesario, en primer lugar, poner especial atención en escribir o seleccionar correctamente la dirección del destinatario. Esto es una acción que depende única y exclusivamente del usuario. Pero adicionalmente, se pueden establecer una serie de medidas técnicas que ayuden a la protección de los datos transmitidos y que queden recogidas en una política de uso del correo electrónico.

DAR MÁS INFORMACIÓN DE LA ESTRICTAMENTE NECESARIA

Si en las publicaciones que una empresa realiza, por ejemplo, en redes sociales, un usuario incluye información valiosa sobre algún cliente, proyecto o simplemente una notificación informativa, podría ser utilizado para que un atacante organizara un ataque de ingeniería social, entre otros. Por ejemplo, si una organización anuncia mediante sus redes sociales, que va a proponer a los miembros que conforman su comunidad, un cambio en las contraseñas, como parte de sus políticas de seguridad, podría ser utilizado por un atacante para generar una página de **phishing** y hacerse con las credenciales de los usuarios de dicho servicio.

Para evitar este tipo de situaciones, simplemente bastará con ser cuidadoso a la hora de hacer públicos datos sobre tu empresa.

LA FALTA DE SENTIDO COMÚN

A pesar de que existen multitud de herramientas cuyo único objetivo es evitar o reducir los riesgos asociados a las fugas de información, la falta de sentido común podría llevar al traste las acciones de estas herramientas. Por ejemplo, si un usuario detiene el antivirus corporativo porque le «ralentiza el funcionamiento del equipo y le impide trabajar», y más tarde se descarga un archivo ejecutable que alguien le ha enviado por correo electrónico, infectando su equipo y la red corporativa, habrá comprometido la información y la seguridad de toda la empresa.

Además, una infección por virus podría acarrear la interrupción de las actividades, llevando a la compañía a una parálisis en su actividad, con la consiguiente pérdida en términos económicos o de reputación.

Por otro lado, aun cuando nuestra empresa no sea objetivo de un malware en particular, no podemos obviar su existencia ni su capacidad de infección. El mero hecho de navegar por Internet puede convertirnos en víctimas de este código malicioso y poner en riesgo la integridad de la información.

Para disminuir estas situaciones, habrá que unificar las medidas y políticas de seguridad de la empresa con el sentido común de los empleados. Esta dupla será más sólida cuanto mayor nivel de formación y concienciación en ciberseguridad tengan los empleados.

FALTA DE MEDIDAS DE SEGURIDAD

En este apartado podríamos aglutinar aquellas ocasiones en las que un empresario o autónomo cree que «su empresa no se puede ser víctima de infecciones o robos de información, ya que se trata de una empresa muy pequeña».

Un puesto de trabajo sin las oportunas medidas de seguridad, por muy pequeña que sea la empresa a la que pertenece, podría ser víctima del robo o pérdida de datos ante las acciones de un atacante o fruto del despiste o desconocimiento del trabajador.

Por ejemplo, si un empleado tira a la papelera los currículums de un proceso de selección, que a su vez van a un contenedor de papel y por algún motivo, quedaran visibles ante terceras personas, estarían poniendo en peligro la confidencialidad de los datos personales contenidos. Esta acción podría acarrear sanciones económicas por parte de la Agencia de Protección de Datos y un daño a su imagen y reputación.

Por otro lado, si se llevaran a cabo instalaciones de programas sin licencia, con generadores de números de serie, podrían sin saberlo, instalar código malicioso que a su vez permitiera accesos remotos u otro tipo de acciones maliciosas.

Para solventar este tipo de situaciones comprometidas se deberá contar con medidas de protección y seguridad, con independencia del sector o tamaño de la empresa. De cara a planificar estas medidas a nivel técnico u organizativo, deberemos desarrollar un Plan Director de Seguridad que analice la situación actual de la empresa, evaluando los riesgos a los que está sometida y aglutinando las medidas y acciones de protección que se llevarán a cabo.

En muchas ocasiones, mitigar los riesgos en el puesto de trabajo no requiere de grandes inversiones o de la implantación de medidas técnicas, sino de incrementar la formación y concienciación de los empleados que conforman la organización, con el fin de establecer una verdadera cultura de seguridad. Pero también es cierto que las medidas técnicas serán necesarias para poner el máximo de barreras a la hora de protegerla y asegurar su integridad, disponibilidad y confidencialidad.

Etiquetas:

- Protección información
- Protección puesto de trabajo
- Políticas
- Buenas prácticas
- Área de informática
- Concienciación
- Empresa

Correo corporativo: sistemas@cas.gov.co Ext: 1012

Elaboró: Jenny Patricia Valderrama Joya